

Threat Actor of the Month #002

Threat Actor:

Scattered Spiders   (UNC3944 /
Octo Tempest)

Author:

B Mahidhar

Role:

CyberSecurity Researcher |
Threat Intelligence | Detection
Engineering | Microsoft Security

Published on 1st of August 2026

Version

1.0

1. Executive Summary

Who are they?

Scattered Spider (also tracked as **UNC3944**, **Octo Tempest**, and other vendor-specific aliases) is a financially motivated cybercriminal group that gained global attention through a series of high-profile intrusions targeting large enterprise organizations across the Technology, Telecommunications, Financial Services, Hospitality, Retail, Business Process Outsourcing (BPO), Gaming, and Media sectors. Unlike many cybercriminal groups that primarily rely on software exploits or custom malware for initial access, Scattered Spider became known for systematically abusing trusted enterprise processes through sophisticated social engineering, identity compromise, and operational reconnaissance. Their campaigns demonstrate a deep understanding of enterprise identity systems, help desk procedures, and administrative workflows.

Why are they dangerous?

Scattered Spider demonstrated that sophisticated cyberattacks do not always depend on exploiting software vulnerabilities or deploying advanced malware during the initial stages of an intrusion. Instead, the group consistently relied on social engineering, help desk impersonation, SIM swapping, SMS phishing, adversary-in-the-middle (AiTM) phishing, and identity compromise to obtain legitimate access to enterprise environments.

Once inside, the attackers leveraged trusted administrative tools, conducted extensive internal reconnaissance, targeted privileged access management (PAM) systems and virtualization infrastructure, and abused legitimate credentials to escalate privileges and move laterally across enterprise networks. In several campaigns, these activities ultimately resulted in large-scale data theft, extortion, and the deployment of ransomware such as ALPHV/BlackCat and, in later campaigns attributed by researchers, DragonForce.

Main targets:

Scattered Spider primarily targets large enterprise organizations, particularly those operating in English-speaking countries such as the United States, Canada, the United Kingdom, and Australia, while more recent campaigns have also included organizations in Singapore and India. The group has shown a notable preference for organizations with large help desk operations, outsourced IT support functions, and environments containing valuable personally identifiable information (PII). Retail, financial services, hospitality, telecommunications, and technology organizations have been frequent targets due to their reliance on identity-driven business operations and the significant operational impact of service disruption.

Primary attack techniques:

- Help Desk Social Engineering
- SMS Phishing (Smishing)
- SIM Swapping
- Adversary-in-the-Middle (AiTM) Phishing
- Credential Theft
- Valid Accounts
- Multi-Factor Authentication (MFA) Bypass
- Privilege Escalation
- Active Directory Enumeration
- Privileged Access Management (PAM) Discovery
- Secrets Discovery (e.g., HashiCorp Vault)
- VMware ESXi & vCenter Targeting
- Lateral Movement (WinRM, RDP, SSH)
- Data Exfiltration
- Double Extortion / Ransomware Deployment

Unlike many threat actors that prioritize exploiting software vulnerabilities during initial access, Scattered Spider consistently demonstrated a preference for compromising trusted identities and abusing enterprise operational processes before leveraging legitimate administrative tools to expand their access across enterprise environments.

Biggest lesson defenders should learn:

From a defender's perspective, Scattered Spider reinforces that **operational trust has become one of the most valuable attack surfaces in modern enterprise environments**. Identity verification procedures, help desk workflows, privileged access management, secrets management platforms, and administrative documentation should be treated as critical security controls rather than routine operational processes. Organizations should implement phishing-resistant authentication, strengthen identity verification procedures, continuously monitor privileged account activity, secure Tier-0 assets, classify sensitive operational documentation, and adopt a defense-in-depth strategy that assumes attackers will eventually obtain a legitimate identity. Modern attacks increasingly exploit business processes rather than software vulnerabilities, making identity governance and operational resilience fundamental components of enterprise security.

Analyst's Note (My notes as a threat researcher):

When I first started researching Scattered Spider, I expected to study another financially motivated ransomware group. However, after reviewing investigations from Mandiant, Microsoft, and CrowdStrike, I found that the group's greatest strength was not sophisticated malware, but its ability to understand and manipulate enterprise operations. What stood out to me most was how effectively the attackers exploited help desk procedures, identity verification processes, privileged administration workflows, and internal documentation to achieve their objectives. This research reinforced an important lesson for me: modern attackers increasingly succeed by abusing operational trust rather than defeating technical security controls. Understanding how organizations manage identities, privileged access, and administrative processes is just as important as understanding malware or software vulnerabilities.

During my research, I found myself paying closer attention to everyday operational practices that often go unnoticed. One example was guidance I recently encountered regarding support ticket attachments, emphasizing that they should never contain unnecessary PII, credentials, or sensitive operational information. Initially, it seemed like a routine administrative recommendation, but after studying Scattered Spider's reconnaissance techniques, it became clear why such guidance matters. Attackers actively search internal documentation, ticketing systems, shared repositories, and knowledge bases to understand enterprise operations. Even seemingly harmless support documentation can provide valuable intelligence that enables privilege escalation or further compromise.

After researching Scattered Spider, I think it's safe to say I've developed a healthy amount of "TRUST ISSUES" when reviewing identity policies, access controls, and help desk procedures.

Threat Actor Profile – Scattered Spider

Field	Information
Threat Actor Name	Scattered Spider
Aliases	UNC3944 (Google Mandiant), Octo Tempest (Microsoft), Scatter Swine (CrowdStrike)
Type	Financially Motivated Cybercriminal Group
Primary Motivation	Financial Gain, Data Theft, Extortion, Ransomware, Credential Theft
First Observed	Around 2022 (Public reporting)

Field	Information
Operational Period	2022 – Present
Primary Targets	Technology, Telecommunications, Financial Services, Retail, Hospitality, Gaming, Business Process Outsourcing (BPO), Media & Entertainment
Known Victims	MGM Resorts, Caesars Entertainment, Marks & Spencer, Co-op, Harrods (and numerous other organizations reported publicly)
Primary Countries Targeted	United States, Canada, United Kingdom, Australia, Singapore, India
Suspected Origin	Primarily English-speaking threat actors; multiple members arrested in the United Kingdom while group activity continued.

Operational Profile – Scattered Spider

Field	Information
Current Status	ACTIVE. Although several suspected members have been arrested, activity attributed to Scattered Spider has continued under the same or related clusters.
Primary Initial Access Methods	Help Desk Social Engineering, SMS Phishing (Smishing), SIM Swapping, Adversary-in-the-Middle (AiTM) Phishing, Credential Theft, Valid Accounts
Primary Attack Focus	Identity Compromise, Privilege Escalation, Internal Reconnaissance, VMware/ESXi Administration, Data Exfiltration, Extortion
Notable Characteristics	Abuses enterprise operational workflows rather than relying primarily on software vulnerabilities. Frequently targets help desks, identity systems, and privileged administration processes.

Field	Information
Skill Level	Moderate to High technical capability with exceptional social engineering proficiency
Stealth	High (Uses legitimate identities and trusted administrative tools to blend with normal activity.)
Technical Sophistication	High operational sophistication with selective use of advanced techniques such as BYOVD (Bring your own Vulnerability - Driver and virtualization targeting.
Social Engineering Sophistication	Very High
Identity Abuse	Very High
Operational Knowledge	Exceptional understanding of enterprise identity management, help desk procedures, outsourced IT operations, and privileged administration workflows.

Why This Group Matters (My Perspective)

After researching Scattered Spider, I couldn't help but compare them with LAPSUS\$. Both groups relied heavily on identity compromise and social engineering, but Scattered Spider felt like a far more operationally mature evolution of those ideas. What fascinated me wasn't their malware or exploitation of software vulnerabilities, it was how well they understood enterprise environments. They didn't simply compromise accounts; they learned how organizations operated. Help desk procedures, identity verification workflows, privileged administration, internal documentation, and virtualization infrastructure all became part of their attack surface. Their operations reinforced an important lesson for me: modern cyberattacks increasingly succeed by exploiting operational trust rather than technical weaknesses. While several suspected members were eventually arrested, their campaigns demonstrated how a determined group can leverage legitimate identities and business processes to compromise even well-defended enterprises.

Interesting Facts

- Several suspected members have been arrested in the United Kingdom; however, activity associated with the group has continued.
- Rather than relying primarily on zero-day vulnerabilities, the group consistently abused help desk procedures and identity verification workflows.
- Internal documentation, SharePoint sites, and knowledge repositories were valuable reconnaissance targets during post-compromise activity.
- The group frequently searched for privileged access management (PAM) platforms and secret management solutions such as HashiCorp Vault.
- VMware ESXi environments became high-value targets because disrupting virtualization infrastructure maximized operational impact during ransomware deployment.
- Their campaigns demonstrate that business processes can be as valuable to attackers as technical vulnerabilities.

2. Timeline

2022 - Public Emergence

Scattered Spider (tracked by multiple vendors as UNC3944, Octo Tempest, and other aliases) began attracting attention in 2022 after conducting financially motivated intrusions against large enterprise organizations. Unlike many traditional cybercriminal groups that relied heavily on malware during initial access, the group quickly distinguished itself by abusing trusted identities, social engineering help desks, SIM swapping, and SMS phishing campaigns to gain legitimate access into enterprise environments.

Early investigations showed that the group preferred manipulating people and operational processes over exploiting software vulnerabilities.

Initial Access Theme: Help Desk Social Engineering, Credential Theft, SIM Swapping

Key Lesson: Enterprise operational processes can become the initial attack surface when identity verification controls are weak.

Early to Mid 2023 - Expansion of Identity-Focused Campaigns

Throughout 2023, Scattered Spider expanded its operations across multiple industries, particularly targeting technology companies, telecommunications providers, financial services, hospitality organizations, and business process outsourcing (BPO) providers. During this period, investigators consistently observed the group's reliance on identity compromise, SMS phishing, adversary-in-the-middle (AiTM) phishing, and valid account abuse instead of traditional malware deployment.

The group's campaigns demonstrated an increasing understanding of enterprise identity systems and administrative workflows.

Initial Access: Identity Compromise

MITRE ATT&CK:

- T1078 – Valid Accounts
- T1566 – Phishing
- T1656 – Impersonation

Key Lesson: Strong authentication alone is insufficient when attackers successfully manipulate identity verification processes.

Late 2023 - Financial Services & Enterprise Operations

By late 2023, Scattered Spider increasingly targeted financial institutions and large enterprise environments where identity systems, outsourced help desks, and privileged administration played critical operational roles.

Following successful identity compromise, the group performed extensive internal reconnaissance by searching SharePoint sites, internal wikis, network shares, administrative documentation, and privileged access management (PAM) solutions. Rather than immediately deploying ransomware, the attackers invested significant effort in understanding how the victim organization operated before escalating privileges.

Primary Activity: Internal Reconnaissance & Privilege Escalation

MITRE ATT&CK:

- T1087 – Account Discovery
- T1018 – Remote System Discovery
- T1069 – Permission Groups Discovery

Key Lesson: Internal documentation and administrative knowledge can become valuable intelligence for attackers after initial compromise.

2024 - VMware & Virtualization Targeting

Mandiant investigations observed Scattered Spider increasingly targeting **VMware vSphere** and **ESXi** environments after obtaining privileged access. Rather than focusing solely on Windows endpoints, the attackers sought control over virtualization infrastructure by identifying **vCenter** administrators, enumerating privileged groups, and abusing legitimate administrative tools to gain access.

Compromising virtualization infrastructure allowed the attackers to maximize operational disruption and increase the effectiveness of subsequent extortion and ransomware operations.

Primary Activity: VMware Administration & Infrastructure Compromise

MITRE ATT&CK:

- T1021 – Remote Services
- T1078 – Valid Accounts
- T1098 – Account Manipulation

Key Lesson: Virtualization infrastructure should be treated as a Tier-0 asset requiring enhanced monitoring and access controls.

September 2024 - Transport for London (TfL) Incident

Scattered Spider was publicly linked to the cyberattack affecting **Transport for London (TfL)**, one of the world's largest public transportation networks. The incident disrupted several online services and operational systems while exposing the challenges of defending large organizations that rely heavily on identity systems and extensive support operations.

Although the attack did not rely on sophisticated software exploitation, investigators indicated that identity compromise and social engineering techniques played a significant role in obtaining initial access. The incident highlighted how attacks against critical public infrastructure can create widespread operational disruption beyond the immediate technical impact.

Initial Access: Identity Compromise & Social Engineering

MITRE ATT&CK:

- T1078 – Valid Accounts
- T1566 – Phishing / Social Engineering
- T1656 – Impersonation

Key Lesson: Organizations providing essential public services should treat identity infrastructure and help desk procedures as critical operational assets, as disruptions can directly affect millions of users.

2024-2025: Retail Campaigns & DragonForce

More recent reporting observed Scattered Spider shifting significant attention toward retail organizations, where access to customer data and personally identifiable information (PII) increased the effectiveness of extortion campaigns. During several incidents, threat actors associated with DragonForce ransomware claimed responsibility for ransomware deployment following identity compromise and enterprise-wide privilege escalation.

These campaigns reinforced that ransomware was often the final stage of a much longer identity-driven intrusion rather than the initial objective.

Primary Activity: Data Exfiltration & Ransomware

MITRE ATT&CK:

- T1041 – Exfiltration Over C2 Channel
- T1486 – Data Encrypted for Impact

Key Lesson: Modern ransomware operations frequently begin with identity compromise long before encryption occurs.

Law Enforcement Actions

Multiple suspected members associated with Scattered Spider have been arrested by law enforcement agencies, particularly in the United Kingdom. While these arrests disrupted portions of the group's operations, security researchers continue to observe campaigns that employ many of the same techniques and operational methodologies.

The group's continued influence demonstrates that successful attack methodologies often persist beyond the individuals who originally developed or popularized them.

Key Lesson: Disrupting individual threat actors is important, but defenders must also address the underlying attack techniques that remain effective across the cybercrime ecosystem.

Timeline Analysis

Looking back at Scattered Spider's evolution, one observation stood out to me more than any individual breach. Unlike many cybercriminal groups that become known for sophisticated malware or exploiting software vulnerabilities, Scattered Spider became successful by understanding how enterprise organizations actually function. They learned how help desks verified users, how privileged administrators managed infrastructure, where operational documentation was stored, and how trusted identities could be abused to move through an environment.

The more I studied their campaigns, the more I realized that their greatest strength wasn't writing advanced malware, it was systematically exploiting operational trust. Identity compromise was only the beginning. What followed was a methodical process of reconnaissance, privilege escalation, and abuse of legitimate enterprise workflows.

3. Victimology

Who Did Scattered Spider Target?

Unlike many cybercriminal groups that focus primarily on a single industry or geographic region, **Scattered Spider targeted organizations whose business operations relied heavily on trusted identities, large-scale customer support operations, and privileged administrative access.** Their victims included organizations across the Technology, Telecommunications, Financial Services, Retail, Hospitality, Business Process Outsourcing (BPO), Gaming, and Media & Entertainment sectors.

Rather than exploiting organizations with weak technical defenses, the group consistently targeted large enterprises where compromising a single trusted identity could provide access to highly valuable business systems. Their campaigns demonstrate that operational maturity alone does not eliminate risk when identity verification processes and administrative workflows become the primary attack surface.

Geographic Focus

Although Scattered Spider has primarily operated against organizations located in English-speaking countries, recent reporting indicates an expansion into additional regions.

Region	Observed Target Sectors
United States	Financial Services, Technology, Telecommunications, Hospitality
United Kingdom	Retail, Public Transportation, Hospitality
Canada	Telecommunications, Enterprise Organizations
Australia	Large Enterprise Organizations
Singapore	Enterprise Organizations
India	Enterprise Organizations (Recent Reporting)

Observation

Unlike many threat actors that primarily target specific governments or regions, **Scattered Spider selected organizations based on operational value rather than geographic location**. Industries with extensive help desk operations, outsourced IT support, large customer bases, valuable personally identifiable information (PII), and privileged identity infrastructure consistently appeared to be attractive targets.

Why These Industries?

After studying Scattered Spider, I noticed that their victim selection followed a consistent operational pattern rather than appearing random.

1. Identity-Driven Organizations

Organizations with complex identity management environments, outsourced support teams, and large help desk operations provided attackers with numerous opportunities to abuse password reset procedures, MFA enrollment, and identity verification workflows.

2. Large Enterprise Environments

Large organizations naturally contain more administrative accounts, privileged infrastructure, third-party vendors, and operational complexity. This complexity increases the likelihood of finding documentation, privileged credentials, or administrative processes that can be abused after initial access.

3. Organizations Containing Valuable Customer Data

Retail, financial services, hospitality, and telecommunications organizations maintain significant amounts of customer information and personally identifiable information (PII). Compromising these environments provides attackers with valuable leverage for extortion and increases the pressure on victims to restore operations quickly.

4. Organizations with Extensive Internal Documentation

One observation that stood out during my research was how frequently Scattered Spider searched SharePoint sites, internal wikis, network shares, administrative documentation, and knowledge repositories following initial access. Rather than immediately deploying ransomware, the attackers invested time in understanding how the organization operated before escalating privileges.

5. Virtualization & Privileged Infrastructure

The group demonstrated a particular interest in privileged administration systems, including VMware vCenter, ESXi environments, Privileged Access Management (PAM) platforms, and secrets management solutions such as HashiCorp Vault. Successfully compromising these systems provided broad administrative control over enterprise infrastructure while maximizing operational impact.

My Perspective

One thing that stood out to me while researching Scattered Spider is that they rarely appeared to choose victims based solely on technical vulnerabilities. Instead, they selected organizations where business operations depended on trusted identities, established operational workflows, and privileged administrative processes.

What surprised me most wasn't that they compromised accounts, it was what they did after gaining access. Before attempting ransomware deployment, they often spent considerable time learning how the organization functioned by studying internal documentation, administrative procedures, privileged groups, and virtualization infrastructure.

To me, this reinforces an important lesson: **attackers don't just exploit technology, they exploit how organizations operate.** The more critical a business process is to daily operations, the more likely it becomes an attractive target for identity-focused threat actors such as Scattered Spider.

During my research, I found multiple public incident reports not limited to Scattered Spider where attackers searched internal documentation, ticketing systems, and operational knowledge repositories after initial access. This reinforced my view that organizations should classify support documentation, ticket attachments, and internal knowledge bases as sensitive assets. Credentials, PII, network diagrams, administrative procedures, and other confidential information should never be routinely stored in operational support systems unless absolutely necessary.

4. Initial Access

Pattern 1 - Help Desk Social Engineering

Overview

Help desk social engineering is one of Scattered Spider's defining initial access techniques. Rather than exploiting software vulnerabilities, the attackers impersonate legitimate employees and manipulate IT support personnel into resetting passwords, enrolling new MFA devices, or modifying authentication methods. This technique enables the group to obtain legitimate access while bypassing many traditional perimeter security controls.

How it worked

The attackers first conducted open-source reconnaissance to collect publicly available information about the target, often using LinkedIn and other professional networking platforms. Armed with employee details, they contacted internal or outsourced help desk personnel, impersonated legitimate users, and attempted to convince support staff to reset passwords, modify MFA settings, or register new authentication methods. Once identity verification was bypassed, the attackers authenticated using legitimate credentials.

Why it succeeded

- Weak identity verification procedures
- Reliance on knowledge-based authentication
- Outsourced help desk operations
- Human trust and urgency
- Inconsistent password reset workflows

MITRE ATT&CK

- T1656 – Impersonation
- T1078 – Valid Accounts
- T1589 – Gather Victim Identity Information

Detection Opportunities

- Password reset activity
- MFA registration changes
- Authentication method modifications
- High-risk sign-ins
- Unusual help desk requests
- Identity lifecycle audit events

Prevention

- Positive identity verification
- FIDO2 / Phishing-resistant MFA
- Callback verification procedures
- Conditional Access
- Help desk security training

Pattern 2 - SMS Phishing (Smishing) & AiTM Phishing

Overview

Scattered Spider frequently combined SMS phishing with adversary-in-the-middle (AiTM) phishing infrastructure to capture credentials, session cookies, and authentication tokens.

How it worked

Victims received SMS messages directing them to attacker-controlled websites that closely resembled legitimate corporate login portals. AiTM frameworks proxied authentication traffic between the victim and the legitimate service, allowing attackers to capture authentication tokens and active sessions.

Why it succeeded

- Trusted SMS communication
- Credential harvesting
- Session cookie theft
- MFA bypass through session hijacking

MITRE ATT&CK

- T1566 – Phishing
- T1557 – Adversary-in-the-Middle
- T1078 – Valid Accounts

Detection Opportunities

- Impossible travel
- Anonymous proxy usage
- Risky sign-ins
- Session anomalies
- Token replay indicators

Prevention

- FIDO2 authentication
- Conditional Access
- Token protection
- Risk-based authentication
- User awareness

Pattern 3 - SIM Swapping

How it worked

The threat actors manipulated telecommunications providers into reassigning a victim's mobile number to an attacker-controlled SIM card. This maneuver allowed the group to intercept SMS-based multi-factor authentication (MFA) codes, effectively gaining control over the victim's digital identity and corporate access.

Why it succeeded

- Inadequate carrier identity verification
- Inherent vulnerabilities in SMS-based MFA
- Highly proficient social engineering techniques

Detection Opportunities

- Modification of MFA registration
- Anomalous phone number updates
- Impossible travel authentication events

Prevention

- Phishing-resistant FIDO2 authentication
- Software-based Authenticator applications
- Telecom carrier-level security PINs
- Robust Conditional Access policies

Pattern 4 - Internal Reconnaissance

Overview

Rather than immediately deploying ransomware, Scattered Spider invested considerable time understanding the victim's environment. The attackers systematically searched internal documentation, SharePoint sites, network drives, knowledge bases, and administrative documentation to understand enterprise operations before escalating privileges.

How it worked

Following initial access, the attackers performed parallel reconnaissance activities. One path focused on organizational documentation, while another targeted privileged access management platforms, secrets management systems such as HashiCorp Vault, and credential repositories. This information enabled the attackers to identify privileged accounts, administrative workflows, and virtualization infrastructure.

Why it succeeded

- Excessive access to documentation
- Weak data classification
- Poor access controls
- Overly permissive SharePoint permissions
- Exposed administrative documentation

MITRE ATT&CK

- T1087 – Account Discovery
- T1083 – File and Directory Discovery
- T1018 – Remote System Discovery
- T1619 – Cloud Storage Object Discovery

Detection Opportunities

- Unusual SharePoint access
- Large document enumeration
- HashiCorp Vault access anomalies
- Administrative document access
- Internal reconnaissance commands

Prevention

- Data classification
- DLP
- Least privilege
- Access reviews
- Secure knowledge repositories

Pattern 5 - Privilege Escalation & VMware Targeting

Overview

Once sufficient knowledge of the environment was obtained, Scattered Spider escalated privileges by identifying privileged groups, abusing legitimate administrative tools, and targeting VMware vCenter and ESXi infrastructure.

How it worked

The attackers enumerated Active Directory groups, verified privileged memberships, remotely queried ESX administrator groups using WinRM, and added attacker-controlled accounts to privileged groups before accessing virtualization infrastructure.

Why it succeeded

- Excessive administrative privileges
- Weak Tier-0 monitoring
- Inadequate PAM controls
- Trusted administrative tools
- Lack of privileged account auditing

MITRE ATT&CK

- T1098 – Account Manipulation
- T1078 – Valid Accounts
- T1021 – Remote Services
- T1069 – Permission Groups Discovery

Detection Opportunities

- ESX Admin group modifications
- Tier-0 account changes
- WinRM execution
- vCenter authentication events
- Privileged group enumeration

Prevention

- PAM
- PIM
- Tier-0 monitoring
- Just-In-Time administration
- VMware hardening
- Continuous auditing

Pattern 6 - Privilege Escalation

Overview

Following successful identity compromise, Scattered Spider focused on obtaining elevated privileges by identifying privileged groups, abusing legitimate administrative tools, and compromising identity infrastructure. Rather than exploiting local privilege escalation vulnerabilities, the group primarily relied on abusing existing enterprise privileges and administrative workflows.

How it worked

- Enumerated Active Directory groups
- Identified privileged identities
- Queried ESX Admin memberships
- Added attacker-controlled accounts into privileged groups
- Accessed VMware vCenter
- Leveraged PAM and secrets discovered during reconnaissance

Why it succeeded

- Excessive privileged accounts
- Weak Tier-0 monitoring
- Over-privileged service accounts
- Poor segregation of duties
- Weak privileged access governance

MITRE ATT&CK

- T1098 – Account Manipulation
- T1078 – Valid Accounts
- T1069 – Permission Groups Discovery
- T1087 – Account Discovery

Detection Opportunities

- New admin group membership
- ESX Admin modifications
- Privileged role assignments
- WinRM usage
- Unexpected vCenter logins
- Tier-0 account activity

Prevention

- PAM
- PIM
- Just-In-Time Administration
- Tier-0 monitoring
- Privileged Access Reviews
- Strong approval workflows

Pattern 7 - Defense Evasion (BYOVD & EDR Tampering)

Overview

In selected intrusions, CrowdStrike observed Scattered Spider attempting to bypass endpoint detection and response (EDR) solutions using the **Bring Your Own Vulnerable Driver (BYOVD)** technique. Rather than directly attacking Windows security mechanisms, the attackers loaded legitimately signed but vulnerable kernel drivers to introduce malicious kernel code capable of interfering with security products.

How it worked

- Obtained administrator privileges
- Loaded a vulnerable signed driver
- Used tools such as **KDMapper**
- Loaded an unsigned malicious kernel driver
- Located EDR kernel modules (e.g., `csagent.sys`)
- Patched EDR routines in memory
- Reduced endpoint visibility before continuing the attack

Why it succeeded

- Trusted **signed** drivers
- Vulnerable drivers remaining available
- Administrator-level privileges
- Insufficient driver blocklist enforcement

MITRE ATT&CK

- T1562.001 – Impair Defenses: Disable or Modify Security Tools
- T1068 – Exploitation for Privilege Escalation
- T1211 – Exploitation for Defense Evasion

Detection Opportunities

- Unsigned or unexpected kernel driver loading
- Vulnerable driver execution
- EDR service tampering
- Kernel memory modification
- Microsoft Defender vulnerable driver blocklist alerts
- Windows Code Integrity events

Prevention

- Enable Microsoft's vulnerable driver blocklist
- Windows Defender Application Control (WDAC)
- Hypervisor-Protected Code Integrity (HVCI)
- Secure Boot
- Restrict administrator privileges
- Monitor kernel driver loading
- Keep vulnerable drivers removed from endpoints

5. Attack Chain

Objective: Understand how Scattered Spider progresses from social engineering and identity compromise to enterprise-wide privilege escalation, virtualization compromise, data theft, and extortion.

Reconnaissance



Help Desk Social Engineering / SMS Phishing / SIM Swapping



Credential Theft & Identity Compromise



Valid Account Access



Persistence



Internal Reconnaissance



Privilege Escalation



Defense Evasion (Optional)
(BYOVD / EDR Tampering)



Lateral Movement



Virtualization Infrastructure Compromise
(vCenter / ESXi)



Data Collection



Data Exfiltration



Ransomware / Extortion

Stage 1 - Reconnaissance

Objective

Identify organizations with large help desk operations, outsourced IT support, privileged identity infrastructure, and valuable customer data.

Activities

- LinkedIn research
- Social media profiling
- Employee enumeration
- Organizational structure mapping
- Help desk identification
- Vendor discovery

MITRE

- Gather Victim Identity Information
- Gather Victim Network Information

Defender Perspective

Most reconnaissance occurs outside the organization's visibility. Employee awareness, limiting publicly available operational information, and monitoring impersonation attempts are the primary defensive measures.

Stage 2 - Initial Access

Objective

Obtain a trusted enterprise identity.

Common Techniques

- Help Desk Social Engineering
- SMS Phishing (Smishing)
- SIM Swapping
- AiTM Phishing
- Credential Theft

Why it Matters

Scattered Spider consistently demonstrated that compromising a trusted identity was often more effective than exploiting technical vulnerabilities.

Stage 3 - Identity Compromise

Objective

Successfully authenticate as a legitimate enterprise user.

Activities

- Password resets
- MFA registration
- Session hijacking
- Valid account authentication

Defender Perspective

Once authentication succeeds, the attacker begins operating with legitimate user permissions. Identity telemetry becomes one of the most valuable sources of detection.

Stage 4 - Persistence

Objective

Maintain reliable access even if passwords are changed.

Activities

- Register additional MFA methods
- Deploy remote management tools
- Create publicly accessible virtual machines
- Maintain multiple authenticated sessions

Detection

- MFA changes
- Remote management software installation
- Persistent authentication sessions
- New remote access tools

Stage 5 - Internal Reconnaissance

Objective

Understand how the organization operates before attempting privilege escalation.

Activities

- Browse SharePoint
- Internal Wikis
- Network Drives
- Administrative Documentation
- Network Diagrams
- HashiCorp Vault
- PAM Solutions
- Local Files
- Cloud Applications
- ADEplorer
- ADRecon
- PingCastle

Goal

Locate:

- privileged identities
- secrets
- administrative workflows
- VMware infrastructure

Defender Perspective

Large-scale document enumeration, access to sensitive documentation, or unexpected use of reconnaissance tools should be investigated immediately.

Stage 6 - Privilege Escalation

Objective

Expand access beyond the compromised identity.

Activities

- Group enumeration
- ESX Admin discovery
- WinRM
- Account manipulation
- Privileged group membership changes
- SecretsDump
- Mimikatz
- GoSecretsDump

Goal

Obtain enterprise administrative privileges.

Stage 7 - Defense Evasion (Observed in Selected Campaigns)

Objective

Reduce endpoint visibility before continuing the intrusion.

Activities

- Bring Your Own Vulnerable Driver (BYOVD)

- KDMapper
- Malicious kernel driver loading
- EDR memory patching
- Security tool tampering

Defender Perspective

Monitor vulnerable driver loading, Code Integrity events, kernel driver activity, and attempts to disable endpoint security products.

Stage 8 - Lateral Movement

Activities

- RDP
- WinRM
- SSH
- Valid Accounts
- VMware vCenter

Goal

Expand access across enterprise infrastructure.

Stage 9 - Virtualization Infrastructure

Objective

Obtain control of VMware infrastructure.

Activities

- vCenter enumeration
- ESXi administration
- ESX Admin group modification
- Virtual machine management

Why it Matters

Compromising virtualization infrastructure enables attackers to impact multiple business-critical systems simultaneously.

Stage 10 - Data Collection

Collect

- PII
- Intellectual Property
- Administrative Documentation
- Secrets
- Password Vaults
- Source Code
- Internal Communications

Stage 11 - Data Exfiltration

Activities

- Rclone
- MEGAsync
- Dropbox
- Azure Storage Explorer

Goal

Steal data to support extortion.

Stage 12 - Extortion & Ransomware

Activities

- Data extortion
- Ransom demands
- ALPHV / BlackCat
- DragonForce (observed in later campaigns)
- Public pressure

Defender Perspective

By this stage, prevention has largely failed. The priority shifts to containment, business continuity, forensic investigation, and recovery.

If I Were Investigating This Attack

It would be:

“Which identity was compromised first, and how was that trust established?”

Scattered Spider consistently demonstrated that the initial compromise often occurred long before ransomware deployment. Their operations relied on abusing trusted identities, understanding enterprise workflows, and gradually expanding access through legitimate administrative processes. Because of this, my investigation would begin with identity telemetry rather than endpoint artifacts.

From there, I would reconstruct the attack chronologically:

1. Identify the initial compromised identity.

- Who was the first compromised user?
- Was the account compromised through help desk social engineering, SMS phishing, SIM swapping, or AiTM phishing?
- Did the account belong to a privileged user or a standard employee?

2. Review authentication and identity events.

- Microsoft Entra ID sign-in logs
- Authentication history
- Impossible travel
- Risky sign-ins
- New device registrations
- MFA registration or authentication method changes
- Password reset events

3. Determine how operational trust was abused.

Rather than immediately searching for malware, I would investigate how the attacker interacted with operational processes.

Questions I would ask include:

- Was the help desk contacted?
- Were password resets requested?
- Were identity verification procedures followed correctly?
- Were new authentication methods registered?
- Did any outsourced support teams handle identity-related requests?

4. Investigate post-compromise reconnaissance.

Once inside, Scattered Spider typically attempted to understand how the organization operated before escalating privileges.

I would investigate access to:

- SharePoint sites
- Internal Wikis
- Network Drives
- Knowledge Bases
- Administrative Runbooks
- Network Diagrams
- HashiCorp Vault
- Privileged Access Management (PAM) systems

5. Map privilege escalation.

Questions I would answer include:

- Were privileged groups enumerated?
- Were new administrative accounts created?
- Were users added to privileged groups?
- Was VMware vCenter accessed?
- Were ESX Admin memberships modified?

6. Investigate defense evasion.

If endpoint visibility appeared limited, I would investigate:

- Vulnerable driver loading (BYOVD)
- EDR tampering
- Security service modifications
- Code Integrity events
- Unexpected kernel driver activity

7. Trace lateral movement.

I would reconstruct movement across the enterprise by reviewing:

- WinRM activity
- RDP connections
- SSH sessions
- Remote management tools
- Administrative logins
- VMware administration activity

8. Identify data collection and exfiltration.

My next objective would be determining:

- What documentation was accessed?
- Were SharePoint repositories enumerated?
- Were secrets retrieved from PAM or HashiCorp Vault?
- Which files were staged?
- Was Rclone, MEGAsync, Dropbox, or Azure Storage Explorer used?

9. Assess business impact and begin containment.

Only after understanding the attack chain would I begin assessing:

- Which identities require immediate containment?
- Which privileged accounts should be reset?
- Which administrative workflows were abused?
- Whether VMware infrastructure was affected.
- Whether customer data or sensitive documentation was exfiltrated.
- Whether ransomware deployment remains a risk.

My Perspective

One thing that stood out to me while researching Scattered Spider is that the investigation doesn't begin with malware, it begins with **trust**.

Unlike many traditional intrusions, Scattered Spider often operates using legitimate identities, trusted administrative tools, and normal business workflows. That makes identity telemetry, authentication logs, help desk records, and privileged access events just as valuable as endpoint evidence during an investigation.

If I had to summarize my investigative approach in one sentence, it would be:

"Don't ask what malware they used first, ask which business process they successfully abused."

6. MITRE ATT&CK Mapping

Overview

Scattered Spider consistently demonstrates that modern cyberattacks rely on a combination of identity compromise, social engineering, legitimate administrative tools, and enterprise operational knowledge rather than solely exploiting software vulnerabilities. The techniques below are mapped to the observed tactics and procedures discussed throughout this report based on publicly available reporting from Mandiant, Microsoft, CrowdStrike, and MITRE ATT&CK.

ATT&CK Tactic	Technique ID	Technique	Observed Usage
Reconnaissance	T1589	Gather Victim Identity Information	Collected employee information from public sources such as LinkedIn and social media.
Reconnaissance	T1591	Gather Victim Organization Information	Identified help desks, vendors, organizational structure, and business operations.
Initial Access	T1656	Impersonation	Impersonated legitimate employees during help desk interactions.
Initial Access	T1566	Phishing	Conducted SMS phishing (Smishing) campaigns to harvest credentials.
Initial Access	T1078	Valid Accounts	Authenticated using compromised legitimate credentials.
Credential Access	T1003	OS Credential Dumping	Used Mimikatz, SecretsDump.py, and GoSecretsDump to obtain credentials.

ATT&CK Tactic	Technique ID	Technique	Observed Usage
Credential Access	T1555	Credentials from Password Stores	Searched password vaults and browser credential stores where applicable.
Discovery	T1087	Account Discovery	Enumerated users and privileged accounts.
Discovery	T1069	Permission Groups Discovery	Identified administrative and ESX Admin groups.
Discovery	T1083	File and Directory Discovery	Searched SharePoint, network drives, local files, and administrative documentation.
Discovery	T1018	Remote System Discovery	Identified internal servers and enterprise infrastructure.
Discovery	T1619	Cloud Storage Object Discovery	Enumerated cloud-hosted documentation and storage resources.
Lateral Movement	T1021	Remote Services	Used WinRM, RDP, SSH, and VMware administration tools.
Persistence	T1098	Account Manipulation	Modified accounts, group memberships, and authentication methods.
Defense Evasion	T1562.001	Impair Defenses: Disable or Modify Security Tools	Attempted to interfere with EDR products using BYOVD techniques.
Privilege Escalation	T1068*	Exploitation for Privilege Escalation	Observed during BYOVD-related abuse of vulnerable drivers (context-dependent).
Collection	T1213	Data from Information Repositories	Collected sensitive information from

ATT&CK Tactic	Technique ID	Technique	Observed Usage
			SharePoint, internal wikis, and knowledge repositories.
Collection	T1005	Data from Local System	Gathered local documentation, configuration files, and credentials.
Exfiltration	T1567	Exfiltration Over Web Service	Used cloud storage services such as Dropbox, MEGA, and Azure Storage Explorer.
Impact	T1486	Data Encrypted for Impact	Deployed ransomware during selected campaigns.

Techniques & Tools Observed

Category	Tool / Utility	Purpose
Credential & Secret Management	Mimikatz	Credential dumping
	SecretsDump.py	Extracting password hashes
	GoSecretsDump	Credential extraction
	HashiCorp Vault	Targeted for secrets discovery
	TruffleHog	Searching repositories for secrets
	GitGuardian	Repository secrets discovery
Reconnaissance & Assessment	ADExplorer	Active Directory reconnaissance
	ADRecon	Domain reconnaissance
	PingCastle	Active Directory security assessment
Remote Access & Administration	WinRM	Remote administration and lateral movement
	RDP	Interactive remote access

Category	Tool / Utility	Purpose
	SSH	Remote administration
Data Exfiltration	Rclone	Data exfiltration
	MEGAsync	Data exfiltration
	Dropbox	Cloud-based exfiltration
	Azure Storage Explorer	Data staging and exfiltration
Defense Evasion	KDMapper	Loading unsigned kernel drivers - BYOVD

MITRE ATT&CK Summary

After mapping Scattered Spider's techniques to the MITRE ATT&CK framework, one trend became immediately apparent to me. The group relies heavily on **valid accounts, identity abuse, discovery, and legitimate administrative tools**, while using comparatively little custom malware during the initial stages of an intrusion. Rather than exploiting a single technical vulnerability, the attackers chain together multiple techniques that individually appear legitimate but collectively enable enterprise-wide compromise.

From a defender's perspective, this reinforces that successful detection requires **correlating identity, endpoint, cloud, and administrative telemetry** rather than relying on isolated alerts. Monitoring a single authentication event or PowerShell execution in isolation may not appear suspicious, but when combined with password resets, privileged group modifications, SharePoint enumeration, and remote administration activity, a much clearer picture of the intrusion emerges.

7. Incident Response

Scenario

Scenario: You are the on-call SOC Analyst. Multiple high-severity incidents have been generated indicating suspicious password reset activity, authentication method modifications, risky sign-ins, impossible travel, and privileged account activity. The alerts suggest a possible Scattered Spider intrusion involving help desk social engineering and identity compromise.

First 15 Minutes - Initial Triage

Objective

Determine whether a legitimate identity has been compromised and prevent the attacker from expanding access.

Immediate Actions

Review Identity Events

- Review Microsoft Entra ID Sign-in Logs
- Review Audit Logs
- Review Risky Users
- Review Risky Sign-ins
- Identify affected identities

Verify Authentication Activity

Check:

- Source IP Address
- Geographic Location
- Device Information
- Authentication Method
- Sign-in Risk Level
- Conditional Access evaluation

Review Identity Changes

Investigate whether:

- Passwords were reset
- Authentication methods changed
- New MFA devices registered
- Recovery methods modified
- New sessions established

Validate with the User

Use an **out-of-band** communication method.

Questions:

- Did you contact the help desk recently?
- Did you request a password reset?
- Did you approve an MFA request?
- Did you register a new phone or device?

First Hour - Investigation

Objective

Determine how far the attacker progressed inside the environment.

Identity Investigation

Review:

- Password Reset Events
- MFA Registration
- Authentication Method Changes
- Risk Detections
- Privileged Role Assignments

Operational Investigation

One thing Scattered Spider consistently demonstrated was abusing operational trust.

I'd investigate:

- Help Desk tickets
- Password reset approvals
- Call recordings (if available)
- Identity verification process
- BPO interactions

Questions I'd Ask

- Which help desk analyst handled the request?
- Were identity verification procedures followed?
- Were callback procedures skipped?
- Was any exception granted?

Post-Compromise Investigation

Determine whether the attacker accessed:

- SharePoint
- Internal Wikis
- Network Drives
- Administrative Documentation
- HashiCorp Vault
- PAM Systems

Privilege Escalation

Investigate:

- ESX Admin group changes
- Domain Admin modifications
- New privileged accounts
- WinRM activity
- vCenter authentication
- Service account abuse

Defense Evasion

Investigate:

- Unexpected kernel driver loading
- BYOVD indicators
- EDR service tampering
- Windows Code Integrity events
- Defender Tamper Protection alerts

Lateral Movement

Review:

- RDP
- WinRM
- SSH
- VMware administration
- Remote management tools

Data Access

Questions I'd Ask

- Were sensitive documents accessed?
- Were support tickets downloaded?
- Were network diagrams viewed?
- Were PAM solutions accessed?
- Were secrets retrieved?

Containment

Objective

Stop the attacker before privilege escalation or ransomware deployment.

Identity

- Disable compromised accounts
- Revoke active sessions
- Force password reset
- Remove unauthorized MFA methods

- Require fresh authentication
- Block risky sign-ins

Endpoint

- Isolate compromised systems
- Block vulnerable drivers
- Remove unauthorized remote access software
- Verify endpoint protection status

Infrastructure

- Disable compromised privileged accounts
- Remove unauthorized group memberships
- **Lock** Tier-0 accounts
- Restrict VMware administrative access

Network

- Block malicious IPs
- Restrict VPN sessions
- Monitor outbound traffic
- Block suspicious remote access

Communication

Notify:

- SOC Manager
- Incident Response Team
- Identity Team
- Infrastructure Team
- VMware Administrators
- Executive Management (if required)

Eradication

Objective

Completely remove attacker access.

Activities

- Remove attacker-created accounts
- Remove unauthorized MFA registrations
- Rotate privileged credentials
- Rotate service account secrets
- Rotate HashiCorp Vault secrets (if accessed)
- Review PAM accounts
- Remove persistence mechanisms
- Verify Tier-0 integrity

Validation

Confirm:

- No malicious sessions remain
- No unauthorized MFA devices remain
- No privileged accounts remain compromised
- VMware infrastructure is secure
- EDR is functioning normally
- No vulnerable drivers remain loaded

Recovery

Objective

Safely restore business operations.

Activities

- Restore user access after verification
- Validate privileged access
- Continue enhanced monitoring
- Review Conditional Access policies
- Confirm business-critical services
- Increase monitoring for identity anomalies

Post-Incident Review

Conduct:

- Root Cause Analysis
- Identity Timeline Reconstruction
- Help Desk Process Review
- Lessons Learned
- Detection Rule Improvements
- Playbook Updates
- User Awareness Review

Lessons Learned

If I were defending against Scattered Spider, my post-incident recommendations would be:

- Strengthen help desk identity verification procedures.
- Adopt phishing-resistant authentication such as FIDO2 wherever possible.
- Continuously monitor authentication method modifications and password reset events.
- Treat Tier-0 assets, VMware infrastructure, and privileged administration systems as critical security assets.
- Apply least privilege to internal documentation, SharePoint sites, knowledge bases, and support ticketing platforms.
- Implement Data Loss Prevention (DLP) and data classification for operational documentation.
- Monitor privileged group modifications and administrative workflow abuse.
- Correlate identity, endpoint, cloud, and infrastructure telemetry rather than relying on isolated alerts.

My Analysis

If I were investigating an incident similar to Scattered Spider, I don't think my first instinct would be to search for malware or ransomware. Instead, I would begin by identifying **which identity was compromised first and how the organization's trust was abused**. From there, I would reconstruct the attack by following the authentication timeline, reviewing help desk interactions, examining privilege escalation, and understanding how the attacker moved through the environment.

This research reinforced something I hadn't fully appreciated before: **modern attackers don't simply compromise users, they compromise the operational trust that organizations place in their identities, support processes, and administrative workflows**. By the time ransomware is deployed, the attacker has often already spent days understanding how the business operates. As defenders, our job is to detect and interrupt that journey long before the final stage of the attack.

10. References

Official Threat Intelligence Sources

- Google Threat Intelligence (Mandiant)
- Microsoft Threat Intelligence
- Microsoft Security Blog
- CrowdStrike Intelligence
- MITRE ATT&CK Framework

Primary Research Reports

- Mandiant – *Proactive Hardening Recommendations for UNC3944*
- Mandiant – *Defending VMware vSphere from UNC3944*
- CrowdStrike – *Scattered Spider Attempts to Avoid Detection with Bring Your Own Vulnerable Driver (BYOVD) Tactic*
- Microsoft Threat Intelligence – *Octo Tempest / Scattered Spider Research*

Additional Reading

- Public incident reports
- Security advisories
- Vendor blogs and technical write-ups
- Public reporting on UK retail campaigns and Transport for London (TfL)

Author's Note

This report reflects **my personal research, understanding, and analysis** of Scattered Spider after reviewing multiple publicly available threat intelligence reports. My objective was not to reproduce vendor publications, but to compare different perspectives, understand the attack lifecycle, and document the lessons I learned throughout my research.

Artificial Intelligence tools were used as writing assistants to improve structure, readability, and refine technical explanations. However, the research process, including reviewing the source material, comparing reports, drawing conclusions, and documenting personal observations, was completed by me.

As with every report in this series, my understanding will continue to evolve as I gain more experience and study additional threat actors.

Tools Used

- ChatGPT
- Google Gemini
- Microsoft Word

8. Skills Practiced

- Threat Intelligence Research
- Threat Actor Profiling
- Threat Hunting Concepts
- MITRE ATT&CK Mapping
- Incident Response Methodology
- Identity Security
- Identity Attack Analysis
- Detection Engineering
- Enterprise Operations Analysis
- Microsoft Sentinel Concepts
- Microsoft Defender XDR Concepts
- Microsoft Entra ID Security
- Active Directory Security
- VMware Security Concepts
- Security Documentation
- Technical Writing
- Critical Thinking
- KQL (*Learning in Progress*)

9. Next Threat Actor

Coming Next...

Threat Actor of the Month #003

🚧 To Be Announced

I promise not another identity related ATP :).

Final Note 🙌

Thank you for taking the time to read my second Threat Actor of the Month report.

When I started this series, my goal wasn't simply to summarize threat intelligence reports. I wanted to understand how attackers think, how defenders investigate, and how enterprise security can be improved by studying real-world intrusions.

Each report in this series is another step in my journey toward becoming a stronger security investigator and detection engineer. My hope is that every issue reflects not only what I learned about the threat actor, but also how my own thinking continues to evolve.

If you have feedback, suggestions, or a different perspective, I'd genuinely appreciate hearing it.

Until the next threat actor...**Stay curious, Stay delusionally grounded and Keep investigating.**

- B Mahidhar